dreamDEX Perps Builder Bounty - feedback track report

I spent the bounty window hammering the dreamDEX perps testnet - the HTTP API, the WebSocket surface, the app front end, and the developer documentation - and I am filing the items I could reproduce cleanly. Everything below was reproduced at least twice against the live testnet on 19 October 2026 before I wrote it up; raw request and response captures sit next to each item. The one security-flavored finding from my testing is being sent privately to the security address, per the program rules, and is not part of this repository.

Environment

Target: https://api.testnet.dreamdex.io plus the testnet app, docs and WS endpoints.
Network: Somnia Tokyo testnet (chainId 50312). Evidence date: 19 October 2026. No credentials are needed to reproduce any item in this folder.

Summary

16 items total - 3 major, 13 normal. By area: API 8, app 2, docs 6.

File	Sev	Area	Item
02-cdn-bucket-listing	normal	app	Public storage bucket listing enabled on cdn.dreamdex.io
03-csp-report-only-leaks-internal-hosts	normal	app	CSP report-only header on app.testnet responses discloses internal dev/staging hosts
04-unauthenticated-metrics-endpoint	normal	API	Unauthenticated /metrics on api.testnet.dreamdex.io exposes internal route table and traffic stats
05-sponsor-warm-unauthenticated-no-ratelimit	normal	API	State-changing POST /api/sponsor/warm accepts unauthenticated calls without rate limiting
06-ws-subscribe-channels-all-fail	major	API	Every documented WebSocket subscribe channel fails with subscription_failed on testnet
07-rest-over-ws-bearer-ignored	major	API	Authenticated REST-over-WebSocket requests never carry the documented bearerToken — 401 for every valid token
08-subscribed-then-error-double-response	normal	API	Subscribe replies subscribed and then subscription_failed for the same frame (contradictory protocol responses)
09-docs-unknown-symbol-400-not-silently-skipped	normal	docs	Market Data docs promise unknown symbols are silently skipped (empty []), live API returns 400 invalid_param
10-docs-comma-symbols-returns-data-not-empty	normal	docs	Market Data docs show comma-separated symbols returning [], live API parses both symbols (200 with data)
11-ws-missing-param-returns-bad-request-envelope-not-invalid-parameters	normal	API	WS operations with missing parameters return a REST-style 404 bad_request envelope instead of the documented invalid_parameters protocol error
12-docs-invalid-interval-error-name-never-returned	normal	docs	Error Handling table documents error name invalid_interval, live API returns invalid_param for the same case
13-perps-dev-page-points-to-chain-50383-while-api-runs-50312	major	docs	Perps developer page documents chain 50383 (Hideki) contract addresses that have no code on the chain the perps API actually runs (50312)
14-docs-21-perp-markets-perp-naming-vs-api-24-usdso-naming	normal	docs	Trader docs list 21 markets as BTC-PERP style names; the testnet API serves 24 perps under BASE:USDso and 404s every documented name
15-docs-testnet-base-url-points-to-stg-not-api-testnet	normal	docs	HTTP API base-URL table sends testnet developers to stg.api.dreamdex.io while the perps testnet host api.testnet.dreamdex.io is undocumented anywhere
16-nul-byte-path-returns-400-empty-violating-json-error-contract	normal	API	NUL byte in the URL path returns 400 with empty body and no Error-Name header, violating the documented JSON error contract

File	Sev	Area	Item
17-login-non-json-content-type-500-leaks-v8-error	normal	API	POST /v0/auth/login with a non-JSON Content-Type returns 500 internal_error and leaks a V8 exception string

The three major items in short

06-ws-subscribe-channels-all-fail (API) - Every documented WebSocket subscribe channel fails with subscription_failed on testnet

07-rest-over-ws-bearer-ignored (API) - Authenticated REST-over-WebSocket requests never carry the documented bearerToken — 401 for every valid token

13-perps-dev-page-points-to-chain-50383-while-api-runs-50312 (docs) - Perps developer page documents chain 50383 (Hideki) contract addresses that have no code on the chain the perps API actually runs (50312)

Item by item - what went wrong

02-cdn-bucket-listing (normal, app). `200`, `Content-Type: application/xml`, body is a full `ListBucketResult` (20164 bytes) enumerating every object key, size and ETag in the bucket. ## Evidence Raw response: evidence/reval-20261019/F21_cdn_listing.xml ## Environment Network: Somnia Tokyo testnet assets CDN. SDK: n/a (raw HTTP). Wallet: n/a. Evidence date: 2026-10...

03-csp-report-only-leaks-internal-hosts (normal, app). The report-only policy lists internal hosts: `https://dev.smk.somnia.host`, `https://hideki-dev.smk.somnia.host`, `https://smk-dev-markets-explorer-hideki-euw4-uzavbo36ra-ez.a.run.app`, `https://api.hideki2.infra.testnet.somnia.network`, `https://price-feed.dev.oracle.somnia.host`, `wss://dream-rpc.somnia.network`. Any client th...

04-unauthenticated-metrics-endpoint (normal, API). `200 text/plain` Prometheus exposition of 128331 bytes served to anyone: `operation="..."` labels for the full internal route table (35 operations incl. `/v0/account/margin/deposit`, `/v0/markets/{symbol}/builder/approve`, `/v0/markets/{symbol}/vault/withdraw`, `/v0/auth/login`, `/v0/ws`, plus `/readyz`, `/healthz`, `/metrics`, ...

05-sponsor-warm-unauthenticated-no-ratelimit (normal, API). Every call returns `204` empty body with no auth challenge; 10 sequential calls completed in 3.41 s, codes `[204 x10]` — no throttle, no backoff, no 429. The endpoint performs server-side sponsor warm-up driven purely by anonymous requests, so it can be amplified for free (resource burn / cache churn) by any party. ## Evidence B...

06-ws-subscribe-channels-all-fail (major, API). - `ping`/`pong` and REST-over-WS public operations work, so the socket itself is healthy. - EVERY channel subscription ends in `{"type":"error","errorName":"subscription_failed","message":"subscription failed to channel: "}`. - For `markets` and `positions` (and `order`) the server first replies `{"type":"subscribed","chan...

07-rest-over-ws-bearer-ignored (major, API). - All variants return `{"id":22,"status":401,"errorName":"unauthorized","payload":{"description":"this request needs a bearer token, and the one presented does not admit it"}}`: plain `bearerToken`, `Bearer ` prefix, `values`-string variant, no payload — five variants total. - Control 1: same frame without any token retur...

08-subscribed-then-error-double-response (normal, API). The server sends `{"type":"subscribed","channel":"markets"}` followed ~0.3s later by `{"type":"error","errorName":"subscription_failed","message":"subscription failed to channel: markets"}`. Same double response observed for `positions` (with a valid token) and `order`. The error carries no reason field, so the client cannot dis...

09-docs-unknown-symbol-400-not-silently-skipped (normal, docs). HTTP 400 `{"status":400,"name":"invalid_param","description":"unknown market symbols: NOPE:USDso","context":{"invalid_symbols":["NOPE:USDso"]}}` on both endpoints. The behavior is fine on its own (strict validation is defensible), but the documented behavior is the opposite of what ships, so every developer following the page wr...

10-docs-comma-symbols-returns-data-not-empty (normal, docs). HTTP 200 `{"orderbooks":[{"symbol":"WBTC:USDso",...},{"symbol":"WETH:USDso",...}]}` — BOTH symbols parsed correctly. The docs' "Wrong" example is actually handled correctly by the server, and the documented `[]` never happens. Developers who trust the page will "fix" working code and avoid a perfectly valid query form. (On the s...

11-ws-missing-param-returns-bad-request-envelope-not-invalid-parameters (normal, API). `{"id":4,"status":404,"payload":{"status":404,"name":"bad_request"}}` — a REST-envelope shape inside the WS protocol, wrong status class (404 for a malformed-request case), and the error name `bad_request` does not exist in the documented error-name tables at all. Two runs, identical response. Clients switching between HTTP and ...

12-docs-invalid-interval-error-name-never-returned (normal, docs). HTTP 400 with `"name":"invalid_param"` and a zod detail payload: `{"status":400,"name":"invalid_param","description":"interval: Invalid option: expected one of ...","context":{"detail":[{"code":"invalid_value",...}]}}`. `invalid_interval` never appears. Any client branching on the documented machine-readable name (the whole poin...

13-perps-dev-page-points-to-chain-50383-while-api-runs-50312 (major, docs). The two deployments are disjoint — eth_getCode: - MarginBank 0x478769E1...: code on 50383 (354B), EMPTY on 50312. - USDso perps page 0xed7993A7...: code on 50383 (56822B), EMPTY on 50312. - USDso contracts page 0x9c32F382...: code on 50312 (7532B), EMPTY on 50383. - API perp contract 0x440f5a79...: code on 50312 (644B), EMPTY on...

14-docs-21-perp-markets-perp-naming-vs-api-24-usdso-naming (normal, docs). Both lookups return 404 `market_not_found`. There is no BTC:USDso or ETH:USDso perp either (only WBTC/WETH and SWBTC* variants), so the primary documented market "BTC-PERP" has no API counterpart under any obvious name, while the API's 24 markets (3 extra, including a SWBTCA-D series) are absent from the doc table. Nothing maps ...

15-docs-testnet-base-url-points-to-stg-not-api-testnet (normal, docs). - The documented testnet host is a different deployment: its spec is a strict subset (missing /v0/markets/{symbol}, /v0/markets/{symbol}/event-positions/{address}, /v0/wallets/{wallet}/event-positions) and its market rows carry no chainId field, while the live perps testnet spec has 54 paths and every market row has chainId 5031...

16-nul-byte-path-returns-400-empty-violating-json-error-contract (normal, API). `HTTP/2 400` with `content-length: 0`, NO content-type, NO Error-Name header, and no body at all — bare edge-server response (headers: via, date, alt-svc only). Reproduced twice on 19 Oct (plus a third time on the staging host by an earlier pass). JSON-parsing SDK clients crash on an empty body where the docs guarantee an envelo...

17-login-non-json-content-type-500-leaks-v8-error (normal, API). Six of six non-JSON-Content-Type requests return: `500 {"status":500,"name":"internal_error","description":"Cannot read properties of undefined (reading 'split')","context":{"detail":"Cannot read properties of undefined (reading 'split')"}}` The unauthenticated public auth endpoint 500s on a plain malformed request and echoes th...

How to reproduce

Each file in feedback/ is self-contained: numbered steps, the exact request or WebSocket frame, the documented expectation, the observed response, and the evidence path. HTTP items are plain curl; WS items need any RFC 6455 client (the examples use python websocket-client). I kept every raw capture from the reproduction sessions, so any item can be replayed end to end.